

Resposta Ponto a Ponto aos Comentários dos Revisores

Manuscrito: “avalia+Tec: Uma Plataforma à Prova de Adulteração para Processos Seletivos Acadêmicos com Verificação de Integridade”

L.D.V. Santos, V.R.Q. Leithardt

4 de março de 2026

Prezado Editor e Revisores,

Agradecemos sinceramente ao Editor e a ambos os Revisores pela avaliação minuciosa, construtiva e perspicaz do nosso manuscrito. Seus comentários identificaram fragilidades importantes que melhoraram substancialmente o rigor científico, a transparência e a honestidade do artigo.

Abordamos todos os comentários levantados por ambos os revisores. A seguir, apresentamos nossas respostas ponto a ponto.

Revisor #1

Comentário 1.1 — Modelo de ameaças e alegação de “imutabilidade”

Comentário do Revisor

O modelo de ameaças contém uma vulnerabilidade crítica que os próprios autores reconhecem: um administrador de servidor com acesso root ao banco de dados poderia reescrever toda a cadeia de hashes de forma consistente. Isso compromete fundamentalmente a alegação central do artigo sobre uma trilha de auditoria “imutável”. Sem ancoragem externa de hashes (por exemplo, blockchain público ou autoridade de carimbo de tempo compatível com RFC 3161), o uso do termo “imutável” é tecnicamente incorreto e enganoso. Os autores devem implementar essa salvaguarda ou revisar substancialmente suas alegações.

Resposta: Concordamos plenamente com esta crítica. O termo “imutável” era tecnicamente impreciso na ausência de ancoragem externa, e agradecemos ao revisor por insistir nesse ponto.

Na versão revisada, tomamos ambas as ações corretivas sugeridas pelo revisor:

1. Implementação de Carimbo de Tempo Confiável RFC 3161. Implementamos um módulo `TimestampService` que submete o resumo SHA-256 de cada inscrição a uma Autoridade de Carimbo de Tempo (TSA) externa compatível com RFC 3161 (padrão: FreeTSA.org). A TSA retorna um token `TimeStampResp` (TSR) assinado criptograficamente, que é armazenado junto ao registro da inscrição. Mesmo um administrador com acesso root não pode forjar um TSR válido sem a chave privada de assinatura da TSA. O código inclui codificação ASN.1 DER, requisição HTTP POST à TSA e lógica de verificação do TSR. Uma migração SQL correspondente (`002_add_rfc3161_timestamp.sql`) adiciona as colunas `tsr_base64`, `tsr_tsa_url` e `tsr_requested_at`. A rota `/api/verify/:protocol` agora retorna os resultados da verificação do TSR juntamente com a verificação de hash existente.
2. Correção terminológica. Todas as ocorrências de “imutável” foram substituídas por “à prova de adulteração” em ambas as versões (inglês e português) do manuscrito, no resumo, nos destaques, no rótulo do diagrama de arquitetura e em todas as descrições técnicas.

Alterações no manuscrito: *Resumo reescrito (ambas as versões); Seção 1 motivação; Seção 2 Funcionalidades do Software — novo parágrafo descrevendo RFC 3161; Seção 3 Modelo de Ameaças — completamente reescrita com três classes de adversários (atacante externo, insider sem privilégios, administrador privilegiado) e análise de risco residual; diagrama de arquitetura: “Armazenamento Imutável de Eventos” → “Armazenamento à Prova de Adulteração”; Seção 7 Conclusões — linguagem de resistência a adulteração. Novos arquivos: `TimestampService.js`, `002_add_rfc3161_timestamp.sql`. Arquivos modificados: `RegisterSubmission.js`, `SqlSubmissionRepository.js`, `JsonSubmissionRepository.js`, `index.js`.*

Comentário 1.2 — Evidência empírica insuficiente

Comentário do Revisor

A evidência empírica para os ganhos reportados de desempenho (redução de 65% no tempo de ciclo, redução de 45,4% no tempo do avaliador) é insuficiente. A amostra ($n = 60$ inscrições, $n = 6$ avaliadores) provém de uma única instituição, e as comparações com fluxos anteriores baseiam-se exclusivamente em dados retrospectivos de pesquisa administrativa auto-reportados, suscetíveis a viés de memória. Nenhum intervalo de confiança, teste formal de significância (ex: Mann–Whitney U) ou comparação com grupo controle é fornecido.

Resposta: Concordamos que a apresentação estatística original era inadequada. O manuscrito revisado agora inclui:

- Intervalos de confiança de 95% para todas as métricas reportadas;
- Testes de Mann–Whitney U (bicaudais) com p -valores exatos: tempo de ciclo $U = 0$, $p = 0,029$; tempo do avaliador $U = 2$, $p = 0,009$;
- Tamanhos de efeito: rank-biserial $r = 1,0$ para tempo de ciclo, Cohen’s $d = 1,88$ (grande) para tempo do avaliador;
- Teste exato de Fisher para taxas de contestação: 0/60 vs. 14/292, $p = 0,069$ (unilateral), explicitamente notado como *não atingindo significância convencional*;
- Reconhecimento explícito de viés de memória, efeito Hawthorne, tamanho amostral pequeno e limitação de instituição única;
- Linguagem moderada: “estimativas preliminares de tamanho de efeito”, “associado a”, “sugere” em vez de alegações causais.

Não adicionamos grupo controle, pois se tratou de uma implantação institucional real onde randomização seria impraticável e eticamente problemática. Essa limitação é explicitamente declarada (Seção 6).

Alterações no manuscrito: *Seção 5 (Impacto) — completamente reescrita com testes estatísticos e linguagem moderada. Seção 6 (Limitações) — novas subseções “Desenho do estudo” e “Qualidade dos dados de baseline”.*

Comentário 1.3 — Novidade superestimada

Comentário do Revisor

A novidade da contribuição criptográfica é superestimada. Hashing SHA-256 e autenticação HMAC-SHA256 em ambiente Node.js representam prática padrão de engenharia de software, não uma contribuição científica. A alegação de que nenhuma plataforma existente integra esses mecanismos requer justificativa mais forte do que a comparação apresentada na Tabela 3.

Resposta: Concordamos plenamente. As primitivas criptográficas individuais (SHA-256, HMAC-SHA256) são de fato bem estabelecidas e sua implementação não constitui uma alegação de novidade científica. O manuscrito revisado reposiciona explicitamente a contribuição:

- Um novo parágrafo “Escopo da contribuição” na Seção 1 declara: “*A contribuição científica reside nessa integração sistemática, e não nas primitivas criptográficas subjacentes.*”
- O resumo agora diz: “*A plataforma combina técnicas criptográficas bem estabelecidas — [...] — em um fluxo de trabalho unificado e de código aberto especificamente projetado para [...]*”
- Todas as alegações de novidade foram substituídas pelo enquadramento de “engenharia de integração”.

Alterações no manuscrito: *Resumo, Seção 1 (novo parágrafo “Escopo da contribuição”), Seção 7 (Conclusões) — contribuição explicitamente enquadrada como engenharia de integração.*

Comentário 1.4 — Tabela comparativa superficial

Comentário do Revisor

A análise comparativa na Tabela 3 é superficial e parece construída para favorecer o avalia+Tec. Notavelmente, o artigo alega conformidade com a LGPD como vantagem exclusiva sem avaliar os mecanismos de conformidade com o GDPR nas plataformas concorrentes. Os critérios de comparação devem ser definidos independentemente do conjunto de funcionalidades do sistema proposto.

Resposta: Concordamos que o formato binário Sim/Não original era redutor e os critérios não eram suficientemente independentes. A Tabela 3 revisada incorpora:

- Escala de pontuação em três níveis (● completo/nativo, ◐ parcial/plugin, ✕ ausente) para evitar a simplificação binária;
- Duas novas colunas que não favorecem o avalia+Tec: “TSA Ext.” (avalia+Tec recebe ◐ parcial, pois a implementação é nova) e “Escala Comprovada” (avalia+Tec recebe ✕, reconhecendo sua implantação em instituição única vs. sistemas em produção com milhões de submissões);
- Uma coluna “GDPR/LGPD” substituindo a coluna exclusiva de LGPD, com notas sobre conformidade via plugins (ex: controles de privacidade do OpenReview);
- Uma coluna “Plugins Ext.” creditando explicitamente HotCRP e OpenReview por seus ecossistemas de extensões;
- Notas metodológicas explicando os critérios de pontuação: “avaliado via documentação publicada, inspeção de código-fonte e matrizes oficiais de funcionalidades.”

Alterações no manuscrito: *Tabela 3 completamente reformulada (10 colunas, escala de 3 níveis, notas de rodapé, coluna GDPR, coluna “Escala Comprovada”).*

Comentário 1.5 — Categoria de submissão incorreta

Comentário do Revisor

O manuscrito foi submetido na categoria “Humanidades, Artes e Ciências Sociais”, o que é claramente incorreto para uma contribuição de engenharia de software. Os autores devem reenviar sob uma área temática apropriada.

Resposta: Agradecemos ao revisor por apontar esse erro administrativo. A resubmissão foi reclassificada na área “Ciência da Computação”, que é a categoria apropriada para uma contribuição de engenharia de software descrevendo uma plataforma web com componentes criptográficos. Pedimos desculpas pelo equívoco.

Alterações no manuscrito: *Metadados da submissão corrigidos para categoria “Ciência da Computação”.*

Revisor #2

Comentário 2.1 — Engenharia de integração, não novidade científica

Comentário do Revisor

O manuscrito, em grande parte, integra primitivas criptográficas bem estabelecidas (SHA-256, HMAC, RBAC, PostgreSQL RLS) sem propor inovações metodológicas, algorítmicas ou arquiteturais. A contribuição parece ser primariamente um esforço de implementação, e não um avanço cientificamente novo. Os autores devem articular claramente o que é fundamentalmente novo além da engenharia de integração.

Resposta: Concordamos e reposicionamos explicitamente a contribuição como engenharia de integração. Veja nossa resposta ao Revisor #1, Comentário 1.3. O manuscrito revisado declara que a contribuição reside na *integração sistemática* de primitivas estabelecidas em um fluxo de trabalho específico do domínio, e não nas primitivas em si. Também observamos que o escopo da SoftwareX abrange explicitamente “software que tem impacto significativo na pesquisa”, independentemente de novidade algorítmica.

Alterações no manuscrito: *Mesmo que Comentário 1.3. Resumo, Seção 1 (parágrafo “Escopo da contribuição”), Seção 7.*

Comentário 2.2 — Estatística inferencial insuficiente

Comentário do Revisor

A redução de 65% no tempo de ciclo e o ganho de 45,4% na eficiência do avaliador reportados baseiam-se em uma implantação pequena de instituição única ($n = 60$ inscrições, $n = 6$ avaliadores). Nenhuma estatística inferencial, intervalo de confiança ou teste de hipóteses é fornecido. Alegações sobre eliminação de disputas e melhorias de eficiência são, portanto, superestimadas e insuficientemente fundamentadas.

Resposta: Integralmente abordado. Veja nossa resposta ao Revisor #1, Comentário 1.2. A Seção 5 revisada agora inclui ICs de 95%, testes de Mann–Whitney U com p -valores exatos, tamanhos de efeito e teste exato de Fisher para taxas de contestação. Todas as alegações foram adequadamente moderadas.

Alterações no manuscrito: *Mesmo que Comentário 1.2. Seção 5 (Impacto), Seção 6 (Limitações).*

Comentário 2.3 — Dados retrospectivos auto-reportados

Comentário do Revisor

A avaliação baseia-se em dados administrativos retrospectivos auto-reportados. Não há baseline controlado, comparação randomizada nem validação longitudinal multi-coorte. Isso enfraquece a credibilidade empírica das melhorias de desempenho reportadas.

Resposta: Reconhecemos essa limitação explicitamente na Seção 6 revisada (Limitações), na nova subseção “Qualidade dos dados de baseline”. O texto agora declara: “*As comparações de baseline baseiam-se em dados retrospectivos de pesquisa administrativa auto-reportados e estão sujeitas a viés de memória. Os avaliadores podem superestimar o tempo anteriormente gasto, inflando o ganho aparente de eficiência. Não existem dados objetivos de rastreamento de tempo para o período pré-implantação.*” Também observamos a ausência de comparação randomizada e explicamos por que a randomização era impraticável em uma implantação institucional real. Validação longitudinal multi-institucional é identificada como trabalho futuro planejado.

Alterações no manuscrito: *Seção 5 — alertas explícitos sobre viés de memória e efeito Hawthorne. Seção 6 — subseção “Qualidade dos dados de baseline”. Seção 7 — trabalho futuro inclui implantações multi-institucionais com desenhos quase-experimentais.*

Comentário 2.4 — Fragilidade do administrador confiável

Comentário do Revisor

O manuscrito assume explicitamente um administrador confiável, o que enfraquece fundamentalmente as garantias de integridade. Uma vez que um usuário root malicioso pode reescrever toda a cadeia de hashes, o sistema não fornece resistência forte a adulterações em contextos institucionais adversariais. As alegações de segurança devem ser atenuadas em conformidade.

Resposta: Abordado pela mesma implementação de RFC 3161 descrita na nossa resposta ao Revisor #1, Comentário 1.1. A Seção 3 revisada agora apresenta um modelo de ameaças com três classes:

1. Atacante externo (não autenticado) — mitigado por TLS, limitação de taxa, sanitização de entrada, autenticação JWT;
2. Insider sem privilégios (usuário autenticado) — mitigado por RBAC, RLS, formulários autenticados por HMAC, trilha de auditoria com cadeia de hashes;
3. Administrador privilegiado (acesso root ao banco) — mitigado por ancoragem externa de hashes via RFC 3161.

A limitação residual é explicitamente declarada: se o administrador suprimir o armazenamento do TSR *antes* da solicitação do carimbo de tempo, nenhuma âncora externa existirá para aquele registro. Isso é identificado como área para melhoria futura (ex: ancoragem contínua em blockchain, gerenciamento de chaves multipartidário).

Alterações no manuscrito: *Seção 3 — reescrita completa. Novo código: `TimestampService.js`. Todo “imutável” → “à prova de adulteração”.*

Comentário 2.5 — Comparação sem rigor

Comentário do Revisor

A comparação com plataformas como SIGAA, OpenReview, EasyChair, HotCRP e SUCUPIRA carece de rigor metodológico. A comparação funcional não considera capacidades de plugins, extensibilidade ou possibilidades alternativas de integração criptográfica. Apresenta uma simplificação binária “Sim/Não” que pode deturpar os sistemas concorrentes.

Resposta: Integralmente abordado. Veja nossa resposta ao Revisor #1, Comentário 1.4. A Tabela 3 revisada utiliza pontuação em três níveis, credita explicitamente ecossistemas de plugins, inclui colunas onde o avalia+Tec recebe nota inferior aos concorrentes e documenta a metodologia de comparação em notas de rodapé.

Alterações no manuscrito: *Mesmo que Comentário 1.4. Tabela 3 reformulada.*

Comentário 2.6 — Sem validação formal de segurança

Comentário do Revisor

Embora SHA-256 e HMAC sejam citados, não há validação formal de segurança, nenhum relatório de teste de penetração, nenhuma auditoria externa e nenhuma verificação de práticas corretas de gerenciamento de chaves. Simplesmente chamar bibliotecas-padrão não garante implantação segura.

Resposta: Concordamos que chamar bibliotecas-padrão não garante implantação segura. O manuscrito revisado aborda isso de duas formas:

1. Evidências positivas: A Seção 3 agora declara que a implementação foi verificada contra o checklist OWASP Top 10 e que o `npm audit` não reporta vulnerabilidades de alta severidade conhecidas nas dependências de produção. Também descrevemos as práticas atuais de gerenciamento de chaves (segredos JWT e chaves HMAC armazenados como variáveis de ambiente, nunca em código-fonte).
2. Limitação honesta: As Seções 3 e 6 (subseção “Segurança”) declaram explicitamente: “*Nenhum teste formal de penetração ou auditoria externa de segurança foi conduzido até o momento; isso representa trabalho futuro planejado.*” e “*Esses não constituem uma avaliação abrangente de segurança.*”

Teste formal de penetração e auditoria externa são listados como trabalho futuro na Seção 7.

Alterações no manuscrito: Seção 3 (Modelo de Ameaças) — menção a OWASP/npm audit, descrição de gerenciamento de chaves. Seção 6 (Limitações) — nova subseção “Segurança”.

Comentário 2.7 — Sem teste de estresse

Comentário do Revisor

Os testes de desempenho foram realizados com 60 inscrições. Nenhum teste de estresse, simulação de usuários concorrentes ou benchmarking de alta carga é apresentado. Não está claro como o sistema se comporta com centenas ou milhares de usuários simultâneos.

Resposta: Agora conduzimos e reportamos testes de carga. Um novo script de teste de carga (`scripts/load-test.js`) utilizando autocannon (ferramenta de benchmarking HTTP para Node.js) foi criado com três cenários: GET / (página inicial), GET /api/verify/:protocol (verificação de integridade) e POST /api/inscricao (criação de inscrição com hashing SHA-256 e carimbo de tempo RFC 3161 assíncrono). Os testes foram executados contra uma instância do servidor avalia+Tec em operação, com 100 e 500 conexões simultâneas por 30 segundos cada.

Uma nova Seção 4.1 (Testes de Carga) e Tabela 5 reportam os resultados medidos:

- A 100 conexões: GET / alcança 1.753 req/s (p50=52 ms, p97,5=98 ms); POST /api/inscricao alcança 1.338 req/s (p50=68 ms, p97,5=133 ms);
- A 500 conexões: operações de leitura sustentam >1.700 req/s, mas a latência de cauda do POST aumenta acentuadamente (p99=8.153 ms) com 1.127 erros de 47.976 requisições, indicando saturação do event loop que confirma a necessidade de escalonamento horizontal além de ~500 escritores concorrentes;
- O texto declara explicitamente que escalonamento horizontal (balanceamento de carga, réplicas de leitura PostgreSQL) é uma extensão arquitetural direta para implantações maiores.

Os resultados brutos completos (JSON estruturado com todos os percentis de latência, throughput e contagem de erros para todas as seis combinações cenário/concorrência) estão incluídos no pacote de replicação (`load-test/load_test_results.json`).

Alterações no manuscrito: Nova Seção 4.1 (Testes de Carga), nova Tabela 5 com dados medidos. Novo arquivo: `scripts/load-test.js`. Pacote de replicação inclui resultados JSON brutos.

Comentário 2.8 — Conformidade com LGPD não demonstrada

Comentário do Revisor

Alegações de conformidade com a LGPD são afirmadas, mas não rigorosamente demonstradas através de mapeamento formal de conformidade, DPIA (Avaliação de Impacto sobre a Proteção de Dados) ou referências de auditoria jurídica. As declarações de conformidade parecem descritivas e não validadas.

Resposta: Reconhecemos que a plena conformidade com a LGPD requer medidas organizacionais, jurídicas e técnicas, e uma única plataforma de software não pode “estar em conformidade com a LGPD” isoladamente. O manuscrito revisado:

1. Substituí “em conformidade com a LGPD” por “design compatível com a LGPD” em todo o texto;
2. Adiciona uma nova Tabela (tab:lgpdmapping) que mapeia artigos específicos da LGPD (Art. 6 I–II, Art. 6 V, Art. 6 VII–VIII, Art. 6 X, Art. 46, Art. 48, Art. 18) aos controles técnicos correspondentes implementados no avalia+Tec;
3. Adiciona um disclaimer explícito: “*A plena conformidade com a LGPD requer políticas institucionais, um RIPD (Relatório de Impacto à Proteção de Dados Pessoais) formal e revisão jurídica por cada organização que implantar o sistema. Nenhum RIPD formal foi conduzido para a implantação atual.*”

Alterações no manuscrito: Seção 2 — terminologia “design compatível com a LGPD”, nova Tabela (tab:lgpdmapping), disclaimer. Seção 6 (Limitações) — nova subseção “Conformidade com a LGPD”. Seção 7 — RIPD listado como trabalho futuro.

Comentário 2.9 — Sem dataset público ou pacote de replicação

Comentário do Revisor

Embora métricas anonimizadas sejam ditas “disponíveis mediante solicitação”, nenhum dataset público ou pacote de replicação é fornecido. Isso limita a transparência e a reprodutibilidade, que são centrais aos padrões da SoftwareX.

Resposta: Concordamos. A declaração revisada de Disponibilidade de Dados agora diz:

“Métricas anonimizadas de implantação, scripts de análise estatística (Python) e o framework de teste de carga estão disponíveis no pacote de replicação em <https://doi.org/10.5281/zenodo.18868994>.”

O pacote de replicação está publicado no Zenodo em <https://doi.org/10.5281/zenodo.18868994>. O pacote contém os seguintes arquivos de evidência:

- data/deployment_metrics.csv — métricas anonimizadas de implantação (sem PII);
- analysis/statistical_analysis.py — script Python reproduzindo todos os ICs, testes de Mann–Whitney U , tamanhos de efeito e teste exato de Fisher;
- analysis/output_statistical_analysis.txt — saída capturada confirmando os valores do artigo;
- load-test/load-test.js — script de benchmarking autocannon;
- load-test/load_test_results.json — JSON estruturado com resultados brutos de todas as seis combinações cenário/concorrência.

Metadados de citação legíveis por máquina são fornecidos via CITATION.cff e .zenodo.json na raiz do repositório.

Alterações no manuscrito: Declaração de Disponibilidade de Dados atualizada. Seção 6 (Limitações) — subseção “Reprodutibilidade” referencia Zenodo. Seção 7 — pacote de replicação mencionado. CITATION.cff e .zenodo.json adicionados.

Comentário 2.10 — Manuscrito prolixo

Comentário do Revisor

O artigo parece prolixo para uma publicação de software original na SoftwareX. Seções descrevendo fundamentos criptográficos e diagramas de fluxo poderiam ser condensadas. Algumas explicações conceituais são repetitivas e inflam o manuscrito sem adicionar profundidade técnica.

Resposta: Condensamos o manuscrito da seguinte forma:

- Removendo explicações redundantes de fundamentos de SHA-256 e HMAC (leitores da SoftwareX são considerados familiarizados com hashing padrão);
- Consolidando texto motivacional repetido entre seções;
- Compactando a discussão da comparação (a Tabela 3 redesenhada transmite mais informação em menos texto);
- Movendo descrições detalhadas de fluxo para o diagrama de arquitetura e sua legenda;
- Usando linguagem mais concisa e direta em todo o texto.

Apesar da adição de novo conteúdo técnico (implementação RFC 3161, testes de carga, tabela de mapeamento LGPD, modelo de ameaças expandido, testes estatísticos, limitações estruturadas), o texto geral está mais focado e menos repetitivo. Estimamos uma redução líquida no volume de prosa de aproximadamente 15% (excluindo tabelas e equações).

Alterações no manuscrito: *Ao longo de todo o manuscrito. Particularmente: Seção 1 (motivação condensada), Seção 2 (primer criptográfico removido), Seção 5 (tabelas substituem descrições prolixas).*

Resumo das Alterações

Rev./Pt	Questão	Ação Tomada
R1.1 / R2.4	Alegação de “imutável”; admin confiável	Implementação RFC 3161 TSA; “à prova de adulteração”; modelo de ameaças com 3 classes
R1.2 / R2.2	Sem estatística inferencial	ICs de 95%, Mann–Whitney U , Fisher exato, tamanhos de efeito, linguagem moderada
R1.3 / R2.1	Novidade superestimada	Contribuição reposicionada como engenharia de integração
R1.4 / R2.5	Comparação superficial	Tabela 3 redesenhada: escala de 3 níveis, 10 colunas, notas metodológicas
R1.5	Categoria incorreta	Reclassificada como “Ciência da Computação”
R2.3	Dados retrospectivos	Viés de memória e confundidores reconhecidos; subseções de limitações adicionadas
R2.6	Sem validação de segurança	Verificação OWASP Top 10, npm audit; limitação honestamente declarada
R2.7	Sem teste de estresse	Testes de carga executados: 1.753 req/s GET, 1.338 req/s POST @100 conn; saturação a 500 conn; JSON bruto no pacote de replicação
R2.8	LGPD não demonstrada	Tabela de mapeamento LGPD, terminologia “compatível com a LGPD”, disclaimer RIPD
R2.9	Sem pacote de replicação	Pacote de replicação publicado no Zenodo (DOI: 10.5281/zenodo.18868994)
R2.10	Prolixo	Texto condensado em ~15%; redundâncias removidas

Confiamos que estas revisões abordam adequadamente todas as preocupações levantadas por ambos os revisores e pelo editor. Permanecemos à disposição dos revisores para quaisquer esclarecimentos adicionais.

Atenciosamente,

L.D.V. Santos e V.R.Q. Leithardt